TLP:CLEAR

INCIDENT REPORT

Hetzner Billing Phishing Sent from Hetzner Cloud over Hijacked DNS

Phishing • DNS Hijacking • Google Redirector Abuse • Cloaking • Credential Theft • Cybercrime

Parameter	Value
Analysis Date	**21 October 2026**
Classification	**Credential phishing: hosting-provider billing lure**
Threat Actor	**Unnamed financially motivated operator (multi-brand, active since at least June 2026); not linked to the parallel YouTube-themed case (High)**
Targets	**Customers of hosting providers (Hetzner, DreamHost, Strato), an AI service and banks**
Affected Systems	**Hetzner accounts of recipients; DNS zones of hijacked domains**
Key Techniques	**DNS takeover of legitimate domains, own MTA on a provider cloud, Google redirector laundering, multi-stage cookie gate**
Threat Level (campaign risk assessment)	**HIGH**
Sources	**Message headers and body; passive DNS, certificate transparency, RDAP, public scan archives**

1. Executive Summary

On 20 October 2026 a billing phishing message impersonating Hetzner Online reached a genuine Hetzner customer, who recognised it and did not interact with it. A separate message investigated in parallel is not related to this campaign (High confidence).

The message was sent from a dedicated VPS inside Hetzner Cloud itself (2[.]29[.]109[.]211). The sender domain, singermali[.]com, is a legitimate domain registered in 2018 at DreamHost whose DNS was taken over: the actor added an MX/A record for its own MTA, an SPF record that authorises only that VPS (-all) and a DKIM key whose selector is a Unix timestamp. As a result SPF, DKIM and DMARC all pass. The only link in the message goes through the Google notification redirector (notifications.googleapis[.]com/email/redirect), which hides the real target (a zlib + base64url-encoded value in the r= parameter) behind a Google domain. The target, hz.azrylin[.]com, sits behind a JavaScript gate and lives on a server that also hosts a cluster of fresh multi-brand look-alikes (Hetzner, DreamHost, Strato, OpenAI/ChatGPT, Piraeus Bank, Openbank). A second hijacked DreamHost domain (jaggery[.]org) uses the same DNS template, and certificates issued on 21 October show that the next wave was being prepared.

Impact: credential theft aimed at hosting/cloud accounts. No compromise of a victim was observed. Campaign risk assessment: High (account control at a hosting provider).

Key findings:

- The phishing is sent from the impersonated provider's own cloud, and passes SPF, DKIM and DMARC because the actor controls the DNS of a hijacked legitimate domain.
- DNS template of the actor on hijacked domains: MX 10 mta.<domain> to a Hetzner Cloud address; v=spf1 ip4:<IP> -all; DMARC p=none with rua=postmaster@<domain>; DKIM selector <unixtime>.<label>.
- Link laundering through a Google redirector: the visible and the first-hop domains belong to Google. The landing page is protected by a multi-stage cookie gate (jscheck, screen, server-side screening) that ends in a redirect to the genuine brand for rejected visitors.
- The campaign is part of an active multi-brand operation (since at least 23 June 2026) with look-alikes of hosting providers, an AI service and banks on two servers (37[.]148[.]201[.]157, 208[.]116[.]19[.]38).

2. Incident Timeline

Date / time	Event
2026-06-23	Server 208[.]116[.]19[.]38 in use (PowerMTA host name)
2026-07-26	First certificates for the DreamHost look-alike panel-dreamhost[.]com
2026-08-24 / 25	OpenAI and Strato look-alikes registered
2026-10-12	azrylin[.]com, azrylin[.]net, azryliz[.]com registered
2026-10-15	Plesk deployed on 37[.]148[.]201[.]157
2026-10-20 ~03:30 UTC	Certificate for hz.azrylin[.]com issued
2026-10-20 06:32:18 UTC	DKIM key created for singermali[.]com (selector = Unix time)
2026-10-20 08:42 – 16:49 UTC	Spam/phishing complaints about 2[.]29[.]109[.]211 in a public abuse database (sending of this campaign)
2026-10-21 ~00:00 – 02:00	Certificates for app-openbank[.]com, gty.singermali[.]com,

UTC	srv.jaggery[.]org: next wave being prepared

3. Hetzner Billing Phishing

3.1 The message

Subject "Update your payment method to avoid suspension"; the text claims that a payment failed and that services will be suspended in 7 days unless the payment method is updated. Display name "Hetznar Online Gmbh" (typo) over support@singermali[.]com; footer with a fake address in London ("24 Commerce Street, Suite 900") while the real company is in Germany; greeting "Dear Customer", no customer number. The message is a single HTML part with an inline PNG logo.

Header observations (all verified):

- Last external hop: mta.singermali[.]com [2[.]29[.]109[.]211] over TLS 1.2; SPF pass for that single address; DKIM pass (d=singermali[.]com, selector 1792477938.singermali, RSA-2048); DMARC pass with p=none.
- The DKIM selector is the Unix time 2026-10-20 06:32:18 UTC: the key was created about two hours before the first reported sending (08:42 UTC).
- Message-ID is in the exact format of Python email.utils.make_msgid() with the host name of a Windows machine (WIN-6U7R9EBBET1), and the MIME boundary is also Python's. The claimed "X-Mailer: Mozilla Thunderbird" contradicts both and is forged. The Date header carries a UTC-07:00 offset (weak indicator).
- Self-written headers "X-Spam-Status: No, score=0.0", "X-Spam-Checker-Version: SpamAssassin (version 3.4.0)", "X-Spam-Report: This message is not spam." on an inbound message, plus Precedence: bulk and X-Auto-Response-Suppress: All.

3.2 Sender infrastructure and DNS takeover

2[.]29[.]109[.]211 belongs to Hetzner Cloud (AS24940, range allocated on 2026-09-29, default Hetzner reverse DNS). The phishing against Hetzner customers is therefore sent from a Hetzner server. The sender domain singermali[.]com has been registered since 2018 and has used DreamHost name servers since 2019; its site stays on DreamHost shared hosting (67[.]205[.]27[.]194, not an indicator). The zone was edited on 2026-10-20 to carry the actor template (section 1). The same template, pointing to another Hetzner Cloud address (178[.]105[.]10[.]8), is present on jaggery[.]org (registered 2004). This is a compromise of the domain owners' accounts, not their complicity (High). Possible source of the DreamHost accounts: the look-alike panel-dreamhost[.]com, active since 26 July (Medium).

3.3 Link laundering and landing page

The button points to notifications.googleapis[.]com/email/redirect with three parameters: an opaque token t=, a signature s= and r=, which is the target URL compressed with zlib and encoded as base64url. Decoding r= reveals the real target on hz.azrylin[.]com. The t= and s= formats are Google's own and are not an actor trait. The landing server answers first with a 72-byte page that sets the cookie jscheck=1 and reloads; with that cookie it returns a second 104-byte page that sets a screen=<width>x<height> cookie from the visitor's screen size and reloads again. This is a multi-stage browser-fingerprint gate: clients that do not execute JavaScript (scanners, curl, crawlers) never pass it, and further stages cannot be excluded; non-victims are shown a decoy blog or are redirected to the genuine hetzner.com. The kit behind the gate was not observed, so the form fields and the exfiltration endpoint are unknown; the likely goal is Hetzner account credentials and card data.

With both cookies set, the server performs a server-side check. A test request carrying both cookies from a non-residential address was answered with HTTP 302 to the genuine hetzner.com and an empty body: the

visitor was rejected, probably on the reputation of the address or because the per-message path had already been used (Medium). The full gate is therefore: jscheck=1, then screen=<width>x<height>, then server-side screening (address, client string, cookies), then either the kit or a redirect to the genuine brand. The kit behind the gate was not observed.

3.4 Look-alike cluster

37[.]148[.]201[.]157 (GoDaddy NL, Plesk since 15 Oct) and 208[.]116[.]19[.]38 (WHG, PowerMTA host name) hold one cluster: moves of panel-dreamhost[.]com and drliny[.]com from one server to the other on 13-16 October, and azrylin.* names split between both servers, link them (High). The names on 37[.]148[.]201[.]157 are all phishing or decoy sites, so this is not shared hosting. Domains: consels-hetzner[.]com (Hetzner), panel-dreamhost[.]com (DreamHost), billing-openia[.]com, billng-chatgpt[.]com, chatgpt-opania[.]com, azryliz[.]com (OpenAI/ChatGPT), app-strato[.]com (Strato), ebanking-piraeusbank[.]com (Piraeus Bank), app-openbank[.]com (Openbank), plus azetd[.]com, ww-one[.]com, ony1[.]net with unclear purpose and the decoy drliny[.]com. Most are registered through Cloudflare Registrar with Cloudflare DNS; origin servers use per-host Let’s Encrypt certificates.

3.5 Operator and target selection

An unnamed financially motivated operator targeting customers of hosting providers, an AI service and banks; active since at least 23 June 2026 and preparing new waves daily. Capabilities: own MTA/PowerMTA, rotation of Hetzner Cloud VPS, DNS takeover of third-party domains, cloaking. No attribution to a named group. Target selection is most likely mass (Medium): the message is impersonal and the operator runs parallel lures against other providers; complaints about the sending address came from several countries over eight hours. A customer-database leak is not supported by any evidence (Low).

4. Relationship to Other Campaigns

A message with a YouTube copyright lure investigated in parallel is not related to this campaign (High confidence): the infrastructure, the kit and the mailer have nothing in common. Link to an earlier August Netflix lure that used the same Google redirector is not confirmed (different mailer and infrastructure; Medium that these are different operators).

5. Indicators of Compromise

All values are defanged. to_ids shows whether the value is suitable for blocking lists. singermali[.]com and jaggery[.]org are compromised legitimate domains: block the subdomains listed below, not the domains themselves. 67[.]205[.]27[.]194 (DreamHost shared hosting), notifications.googleapis.com and youtube.studio are not indicators.

Type	Value	Context / confidence	to_ids
IP	2[.]29[.]109[.]211	Actor MTA, Hetzner Cloud VPS (AS24940, HEL1 range). High	true (short-lived)
IP	178[.]105[.]10[.]8	Prepared MTA for mta.jaggery[.]org (AS24940). Medium	true
IP	37[.]148[.]201[.]157	Landing-page host (GoDaddy NL / Host Europe, AS21499, Plesk). High	true

IP	208[.]116[.]19[.]38	Landing-page / PowerMTA host (WHG, AS209341). High	true
Domain	azrylin[.]com	Actor domain, registered 2026-10-12 (Cloudflare Registrar). High	true
Hostname	hz.azrylin[.]com	Landing host for the Hetzner lure. High	true
Domain	azrylin[.]net	Actor domain. High	true
Hostname	account-one.azrylin[.]net	Actor host on 37[.]148[.]201[.]157. High	true
Domain	azryliz[.]com	Actor domain (OpenAI/ChatGPT billing lure). High	true
Hostname	mta.singermali[.]com	Actor MTA name on a hijacked-DNS domain. High	true
Hostname	gty.singermali[.]com	Landing host being prepared (certificate issued 2026-10-21). High	true
Hostname	mta.jaggery[.]org	Same DNS template, MTA on 178[.]105[.]10[.]8. High	true
Hostname	srv.jaggery[.]org	Landing host being prepared (certificate issued 2026-10-21). High	true
Domain	singermali[.]com	COMPROMISED LEGITIMATE DOMAIN (registered 2018, DreamHost; DNS taken over). Victim, do not block as actor infrastructure. High	false
Domain	jaggery[.]org	COMPROMISED LEGITIMATE DOMAIN (registered 2004, DreamHost; same DNS template). Victim. High	false
Domain	consels-hetzner[.]com	Hetzner look-alike. High	true
Domain	panel-dreamhost[.]com	DreamHost look-alike, certificates since 2026-07-26; possible source of the hijacked DreamHost accounts (Medium). High	true
Domain	billing-openia[.]com	OpenAI look-alike. High	true
Domain	billng-chatgpt[.]com	OpenAI look-alike. High	true
Domain	chatgpt-opania[.]com	OpenAI look-alike (incl. billing[.] subdomain). High	true
Domain	app-strato[.]com	Strato look-alike. High	true

Domain	ebanking-piraeusbank[.]com	Piraeus Bank look-alike. High	true
Domain	app-openbank[.]com	Openbank look-alike (certificate 2026-10-21). High	true
Domain	azetd[.]com	Same cluster, purpose unclear. Medium	true
Domain	ww-one[.]com	Same cluster, purpose unclear. Medium	true
Domain	ony1[.]net	Same cluster, purpose unclear. Medium	true
Domain	drliny[.]com	Cluster decoy site ("recipes" blog). Medium	false (decoy)
Domain	ayalti[.]com	Apex of the PowerMTA node (A also points to a third-party address). Medium	false
Hostname	pmta.ayalti[.]com	PowerMTA node on 208[.]116[.]19[.]38. Medium	true
Email	support@singermali[.]com	From / Return-Path of this campaign (address on a hijacked domain). High	false
Email	unsubscribe@singermali[.]com	List-Unsubscribe of this campaign. High	false
Header	WIN-6U7R9EBBET1	Host part of Message-ID (sender Windows host). High	false
Header	s=1792477938.singermali	DKIM selector = Unix time 2026-10-20 06:32:18 UTC. High	false
Header	^\d{10}\.[a-z]+$	DKIM selector pattern of the actor. High	false
String	Hetznar Online Gmbh	Display name (typo) of the lure. High	false
String	24 Commerce Street, Suite 900	Fake London address in the footer. High	false
String	Update your payment method to avoid suspension	Subject of the lure. High	false
String	document.cookie='jscheck=1; path=/'; location.reload();	Entire 72-byte body of the landing gate. High	false
String	document.cookie='screen='+screen.width+'x'+screen.height+'; path=/'; location.reload();	Entire 104-byte body of the second gate stage (set after jscheck=1). High	false
SHA256	5297362709b04b678399af1d68137fb857086149a275e1758760da79f1741132	Inline logo PNG of the lure (likely a genuine Hetzner press logo; weak indicator). Medium	false
SHA256	6d6054771a352d3d54c81d54d18af6c3ee06ce3ebf7d4d960d4180c41529e965	104-byte second-stage gate page (screen=WxH cookie). High	false

SHA256	1ffd13d1c1c64480376a47ed7c3c257d4e39df2ede1af1d6c52007b699c2a7c1	72-byte stage-1 gate page of hz.azrylin[.]com. High	false

6. MITRE ATT&CK Mapping

Tactic	Technique	ID	Evidence / status
Reconnaissance	Search Open Technical Databases	T1596	Possible selection of hosting customers by ASN. Possible
Reconnaissance	Gather Victim Identity Information: Email Addresses	T1589.002	Role-based addresses (info@, hello@ style). Possible
Resource Development	Acquire Infrastructure: Domains	T1583.001	azrylin.*, look-alike cluster. Confirmed
Resource Development	Acquire Infrastructure: VPS	T1583.003	Hetzner Cloud MTA; Plesk hosts at GoDaddy NL and WHG. Confirmed
Resource Development	Compromise Infrastructure: Domains	T1584.001	DNS of singermali[.]com and jaggery[.]org under actor control. Confirmed
Resource Development	Acquire Infrastructure: Web Services	T1583.006	Google notification redirector. Confirmed
Resource Development	Stage Capabilities: Link Target	T1608.005	hz.azrylin[.]com. Confirmed
Initial Access	Phishing: Spearphishing Link	T1566.002	Link in the billing message. Confirmed
Initial Access	Valid Accounts: Cloud Accounts	T1078.004	Goal: Hetzner accounts. Hypothesis
Execution	User Execution: Malicious Link	T1204.001	Click required. Confirmed (intent)
Defense Evasion	Impersonation	T1656	Hetzner billing. Confirmed
Defense Evasion	Masquerading: Match Legitimate Resource Name or Location	T1036.005	"Hetznar Online", consels-hetzner[.]com. Confirmed

Laundering through a Google redirector and cloaking (jscheck/screen cookie gate, server-side screening, decoy blogs, redirect to the genuine brand) do not map precisely to ATT&CK and are described in the text.

7. Detection

7.1 Mail

- Links to notifications.googleapis.com/email/redirect in messages whose From is not Google: decode r= (Python: zlib.decompress(base64.urlsafe_b64decode(r + "=" * (-len(r) % 4)))) and score the decoded target, not the Google domain.
- DKIM selector matching ^\d{10}\.[a-z0-9-]+$ (selector = Unix time, a key created hours before sending).
- Message-ID matching ^<\d{12}\.\d+\.\d{15,20}@WIN-[A-Z0-9]{11}>$ together with X-Mailer: Mozilla Thunderbird.
- An inbound external message carrying self-written X-Spam-Status: No, score=0.0 and X-Spam-Report: This message is not spam.
- Display name containing "hetzn" while the From domain is not hetzner.com (also for other brands: display-name/domain mismatch).
- DNS: a domain whose MX/A points to an mta.<domain> host, with SPF "v=spf1 ip4:<single IP> -all" and DMARC p=none with rua=postmaster@<same domain>, changed shortly before sending.

7.2 Network and content (YARA / proxy / crawler strings)

- HTTP response body exactly equal to: <script>document.cookie='jscheck=1; path=/'; location.reload();</script> (gate, stage 1).
- HTTP response body starting with <script>document.cookie='screen='+screen.width+'x'+screen.height followed by location.reload() (gate, stage 2, 104 bytes). Both strings together (jscheck=1 and screen='+screen.width+'x'+screen.height) identify the gate.
- A host that, after the jscheck and screen cookies are set, answers 302 to the genuine brand domain with an empty body (screening outcome of the gate).
- Newly issued certificates and new names on 37[.]148[.]201[.]157 and 208[.]116[.]19[.]38 should be treated as new waves.

8. Recommendations

Immediate actions

- Block or alert on the indicators marked to_ids=true; do not block singermali[.]com and jaggery[.]org as wholesale domains.
- Add the detection rules of section 8 to the mail gateway and the web proxy; hunt retrospectively for the Hetzner-branded subject and for redirector links with an undecoded r= parameter.
- Customers of hosting providers: genuine invoices of Hetzner are sent from noreply.billing@hetzner.com; check billing only by opening the console directly, never through links in mail. Forward suspicious mail with full headers to the provider’s abuse or support channel as its documentation describes.
- Owners of domains at shared registrars/DNS providers (DreamHost and others): review DNS zones for unknown MX, SPF and DKIM records, enable two-factor authentication on the control panel.

Long-term mitigations

- Publish DMARC p=quarantine/reject and monitor DNS changes of own domains; alert on new DKIM selectors and on SPF changes.
- Mail security should not treat a Google domain in a link as a trust signal: resolve the redirector target before scoring.
- Provider-side: monitor outbound phishing from own cloud ranges, especially from newly allocated blocks; act promptly on abuse reports against brand impersonation of the provider itself.
- Put the two server addresses of section 5 under passive-DNS and certificate monitoring.

9. Confidence and Limitations

Conclusion	Confidence
The message is credential phishing	High
2[.]29[.]109[.]211 is an actor VPS inside Hetzner Cloud	High
singermali[.]com and jaggery[.]org are legitimate domains with hijacked DNS	High

Sender and landing page of this campaign belong to one operator; look-alike cluster on two servers	High
panel-dreamhost[.]com is the source of the hijacked DreamHost accounts	Medium
Target selection by hosting ASN	Medium
Not related to the parallel YouTube-themed message	High
Kit (fields, exfiltration)	Not established (gate)

Gaps: the kit behind the gate was not observed (the gate rejected the test request); the source of the DreamHost accounts is a hypothesis. All pages and indicators reflect the state of 21 October 2026 and the infrastructure rotates daily.

10. References

- Hetzner Docs, "Phishing email collection" (docs.hetzner.com/general/security-and-identify/phishing-email-collection/).
- Mimecast, "Google Redirect Abuse"; TechRepublic, "Trusted Google Alerts Hijacked" (abuse of Google redirectors in phishing).
- Passive DNS, certificate transparency, RDAP/WHOIS, public URL-scan archives and public abuse databases (state of 21 October 2026).

Report date: 2026-10-21

TLP:CLEAR — This document may be distributed without restriction.